

Cyber Kill Chain

1. **Reconnaissance:** In the first stage, the attacker gathers information about the target
2. **Weaponisation:** Once proper reconnaissance is conducted, the attacker creates a deliverable payload or modifies an existing one based on the target system's vulnerabilities
3. **Delivery:** Once ready, the attacker sends the weaponised payload to the target
4. **Exploitation:** Once executed, the payload exploits a vulnerability in the target's system
5. **Installation:** The exploitation enables the attacker to install a backdoor or malware to maintain persistence in the target's environment
6. **Command & Control (C2):** Using the installed backdoor, the attacker can control the compromised system
7. **Actions on Objectives:** Reaching this far, the attacker can now carry out further actions such as data exfiltration or other systems' exploitation

Reconnaissance

Passive Reconnaissance

the attacker performs their activities without making any "noise," for example, using open-source intelligence (OSINT)

examples that come to mind are the WHOIS and DNS databases. The WHOIS database can reveal contact information, registration dates, and domain owners unless hidden using a privacy service add-on. Querying the DNS database can reveal the DNS servers and public servers' IP addresses. Other examples of passive reconnaissance include website reconnaissance by crawling and scraping, social media reconnaissance, and Google Dorking, i.e., using search engines to reveal sensitive information and confidential files.

Active Reconnaissance

the attacker cannot remain completely quiet and invisible; it requires some form of interaction with the target organisation, such as using social engineering against the target's personnel or scanning a target system for vulnerabilities.

active reconnaissance can get noisy. One typical example is network port scanning, which identifies live hosts and running services. More intrusive examples include vulnerability scanning to identify weaknesses in the target's public services. Furthermore, physical reconnaissance is typical, where the attacker might visit the target's premises to identify entry points, study the security measures, and observe personnel behaviour.

Countermeasures Against Reconnaissance: Examples

Defence tactics include minimising public information exposure. This countermeasure is achieved by limiting the information on websites, social media accounts, and DNS records

Monitoring and analysing network traffic and logs is a must to detect vulnerabilities and network port scans.

Weaponisation

Based on the information the attacker has gathered about the target systems, they can create a payload tailored to exploit the discovered weaknesses.

Many attackers resort to the use of obfuscation or encryption to evade detection.

Weaponisation: Examples

Attackers might use one of the available exploit kits. An exploit kit is an automated platform containing various exploits for various vulnerabilities

Attackers usually rely on creating Microsoft Office documents with malicious macros. If macros are enabled, a macro executes a saved set of instructions when the document is opened.

Once the malicious file is ready, the attacker might craft a phishing email with a malicious attachment, set up a web page to host it or save it on a USB memory drive

Countermeasures Against Weaponisation: Examples

On the defender's side, user training is indispensable. When a user receives an email, they need to be careful if it contains any attachments; moreover, they should know how to inspect the email source to check its legitimacy

User cyber security training is a continuous process and an indispensable piece of any solid defence.

Delivery

pick an appropriate delivery method using the information gathered from reconnaissance

Delivery: Examples

- **Phishing emails:** These emails usually contain malicious attachments but might use links to malicious downloads. File names play a significant role in this attack; `invoice.pdf.exe` might trick the target user, unlike `program.exe`.
- **Spear phishing emails** refer to a targeted attack where the emails are crafted to resemble legitimate communication from a source known or trusted by the recipient. For example, the sender's name and email address are spoofed to appear as the recipient's manager.

- **Malicious web links:** The attacker might host the exploit kits on public websites. Domain spoofing and URL shortening are also used to make the links appear less suspicious.
- **File-sharing platforms:** Attackers might upload malicious files to file-sharing web services, relying on people's familiarity with the providers.
- **Malvertising:** The attackers show advertisements on legitimate websites to redirect users to the malicious page.
- **SMS Phishing (Smishing):** The attacker sends text messages with malicious links or instructions to download malware.
- **Social engineering:** The attacker might convince an unsuspecting user to download and run a malicious program.
- **Physical means of delivery:** The malicious code might be saved on a USB flash memory and left in an accessible location. Another example is mailing an innocuous-looking DVD containing the malicious program. The attacker must always provide a convincing context, such as the DVD containing a catalogue of interest to the target personnel.

Exploitation

Exploitation can take various forms, such as a software vulnerability, a weak password, or a system misconfiguration.

Exploitation: Examples

The most straightforward approach is targeting a password-based authentication system.

the attacker can use phishing or more sophisticated techniques to trick the user into submitting their password.

Software vulnerabilities present another door for attackers. Vulnerabilities cover both client systems and network services.

Sometimes, an exploit is made available before the vendor becomes aware that a vulnerability exists in their product; in this case, it is called a zero-day exploit.

Countermeasures Against Exploitation: Examples

Password requirements should be enforced, and multi-factor authentication (MFA) should be required to harden password-based authentication. MFA prevents an attacker from achieving any gain, even with a valid set of login credentials.

Patch management for servers and clients is a must to eradicate known vulnerabilities. Furthermore, vulnerability scanning is necessary to discover any vulnerabilities left unpatched.

Intrusion Prevention Systems (IPSs) can play a significant role in blocking various exploitation attempts by inspecting the traffic for known exploits. Web Application Firewalls (WAFs) can block a variety of attacks against web applications, such as SQL injection, cross-site scripting (XSS), and cross-site request forgery (CSRF).

Installation

the installation phase ensures persistent access to the exploited system

Installation: Examples

To maintain persistent access, sometimes creating scheduled tasks in MS Windows or setting a cron job in Linux systems is necessary. Other times, they need to modify startup scripts or configuration files. Installing a new service in Windows or a daemon in Linux systems is one possible approach.

Attackers might resort to installing malware, creating backdoors, or installing rootkits, among other things. Furthermore, they try to take advantage of the system's built-in functions, such as legitimate Windows tools and binaries, also known as living-off-the-land binaries (LOLBins).

Countermeasures Against Installation: Examples

Endpoint Detection and Response (EDR) allows monitoring endpoints for suspicious activities, such as unusual process creation, file modification in sensitive directories, and unexpected network connections.

Regular system audits and comparisons against a secure baseline are necessary to identify unauthorised changes, such as newly created user accounts or newly installed services, and revert them to their original state.

application allowlisting, which prevents the execution of unauthorised or malicious software by allowing only approved applications to run.

Command and Control

aims to establish this covert communication channel for use in the next phase. In this phase, the attacker sets up the C2 communication channel between the compromised systems and their own infrastructure.

create such infrastructure as domain names, IP addresses, and cloud services. To evade detection, the attacker might resort to different methods

Command and Control: Examples

using common application layer protocols such as HTTP, HTTPS, DNS, and SMTP for C2 communication, which allows blending in with legitimate traffic

C2 infrastructure may use encrypted channels such as HTTPS to hide from network monitoring tools.

Regarding domain addresses, C2 communication can use social media platforms, such as X direct messages, to send commands to a botnet. Another option is using legitimate cloud services, such as Dropbox and Google Docs, especially for data exfiltration.

If the attacker registers their own domain name and uses it to establish the C2 infrastructure, it will be too easy to take it down. Therefore, the C2 relies on various techniques to ensure resilient communications. Examples include Domain Registration Algorithms (DGAs) and Fast Flux. **DGA** refers to creating a vast number of domain names, for example, 50 000, using a predefined algorithm.

Fast Flux associates hundreds or thousands of IP addresses with a single domain name; furthermore, these IP addresses are swapped every few minutes. Compromised devices, e.g., IoT devices, act as proxies to forward traffic to the hidden C2 server. If any IP address, i.e., proxy node, gets blocked, the malware automatically switches to the following IP address.

Countermeasures against Command and Control: Examples

Network monitoring via firewalls, IDS, and IPS plays a significant role in detecting and blocking C2 traffic. It is essential to watch for unusual traffic patterns and volumes and connections to known malicious IP addresses.

DNS traffic can be used to tunnel C2 traffic, monitoring DNS traffic and analysing DNS queries is equally vital, especially when stumbling across unusually long ones or detecting high volumes of requests to suspicious domains. Moreover, because web shells use HTTP and HTTPS protocols, monitoring web traffic helps detect suspicious connections, while content filtering can block access to suspicious URLs.

encryption inspection would be necessary to decrypt and inspect encrypted traffic to detect C2 communication using HTTPS.

step further and deploy honeypots to detect and analyse C2 communication attempts and monitor attacker behaviour.

Actions on Objectives

the attacker executes their original goals, which range from data exfiltration (information theft) to service disruption

Actions on Objectives: Examples

if the attacker is only interested in seeking damage, they can launch a destructive attack by deleting or corrupting data to disrupt normal system operations.

attackers might be after financial gain and “quick riches”, usually by carrying out a ransomware attack

Or they might be trying to get rich more discreetly, such as financial theft via unauthorised wire transfers or other fraudulent transactions.

In a covert attack, such as industrial and political espionage, the attackers would be most interested in stealing sensitive files from their target, commonly called data exfiltration. Alternatively, if the attacker is interested in getting access to other systems on the target network, they will try to stealthily compromise other systems on the network, i.e., lateral movement.

the threat actor might be interested in manipulating Industrial Control Systems (ICSs). It is also equally plausible that this is preceded by establishing a long-term persistent presence so that they carry out their attack at a time of their choosing.

Countermeasures Against Actions on Objectives: Examples

Data Loss Prevention (DLP) solutions can play a key role in preventing unauthorised data exfiltration.

a reliable backup and recovery plan is indispensable to mitigate ransomware and other destructive attacks.

consider network segmentation and strict access controls